

JORGE ALVIM ADVOCACIA & LEGALTECH

PARECER TÉCNICO: AUDITORIA DE ARQUITETURA CLOUD & ENGENHARIA DE SOFTWARE

Dr. Jorge Eduardo da Silva Alvim • OAB/MG 222.943 • Juiz de Fora - MG • Padrão Enterprise (Prov. 205/2021 OAB & LGPD)

PRINCIPAIS PARÂMETROS REAIS AUDITADOS (CALIBRAÇÃO DO AMBIENTE EM PRODUÇÃO):

- Servidor VPS: Contabo (Datacenter Alemanha/Europa, KVM virtualizado).
- Volume de Dados: Fase de testes e implantação inicial (poucos dados cadastrados).
- Banco de Dados: SQLite local via modo WAL (Write-Ahead Logging) com 41 índices.
- Governança LGPD: Botão de exclusão de cadastro existente; expurgo de arquivos ainda manual.

1. SCORECARD DE MATURIDADE ARQUITETURAL

DIAGNÓSTICO INICIAL

Pilar Computacional	Estado Real no Código	Nível de Risco	Veredito do Arquiteto
1. Persistência & CRUD	SQLite WAL com 41 índices em arquivo local leads.db	MÉDIO	Ultra-rápido (<5ms), mas vulnerável sem réplica
2. Rede Internacional	VPS Contabo em Frankfurt (RTT ~250ms p/ o Brasil)	CRÍTICO	Exige Cloudflare Edge p/ cache de estáticos no Brasil.
3. Segredos & Auth	Variáveis .env + JWT tokens com fallback estático	MÉDIO	Blindar segredos de produção e rotatividade de
4. LGPD vs Estatuto OAB	DELETE físico no Portal do Cliente sem trava processual	CRÍTICO	Substituir por Soft Delete e trava ética do Art. 16, I.
5. Retenção de Arquivos	Storage local acumulativo sem expurgo automático	MÉDIO	Criar job cron de saneamento de anexos temporários.

2. PERSISTÊNCIA & OPERAÇÕES CRUD (SQLITE WAL EM PRODUÇÃO)

ALTA VELOCIDADE

- SQLite em Modo WAL (Write-Ahead Logging): Para a escala de até 50.000 clientes e 100.000 andamentos, o SQLite com WAL é tecnicamente superior a um banco gerenciado remoto, pois opera in-memory/NVMe sem latência TCP, atingindo leituras em microssegundos com consumo inferior a 50 MB de RAM.
- O Perigo do Hard Delete no Direito: O código executa DELETE FROM clients WHERE id = ?. No ramo jurídico, se um cliente excluir sua conta possuindo processos ativos, causa-se quebra de integridade referencial ou perda de acervo probatório. A solução mandatória é Soft Delete (status = "inativo_lgpd" e deleted_at TIMESTAMP) com trava legal.

3. INFRAESTRUTURA CONTABO (ALEMANHA) & LATÊNCIA TRANSATLÂNTICA

MITIGAÇÃO EDGE

- Diagnóstico de Latência: Servidores em Frankfurt possuem RTT de 220ms a 320ms para o Brasil. Em redes móveis 4G/5G, múltiplos round-trips para carregar arquivos CSS, JS e imagens degradam a experiência do usuário se não houver camada de borda.
- Solução Enterprise Custo Zero (Cloudflare Edge): Inserir o proxy reverso da Cloudflare na frente do VPS Contabo. Os arquivos estáticos passam a ser servidos dos data centers de São Paulo e Rio de Janeiro (<15ms). A Contabo processa unicamente as chamadas JSON de API (/api/*).
- Disaster Recovery Plan (DRP 3-2-1): O script backup.sh gera snapshots integros via VACUUM INTO e compacta o storage. Contudo, manter backups no mesmo disco da Contabo é ponto único de falha. Exige-se exportação criptografada para Google Drive ou AWS S3.

JORGE ALVIM ADVOCACIA & LEGALTECH

PARECER TÉCNICO: AUDITORIA DE ARQUITETURA CLOUD & ENGENHARIA DE SOFTWARE

Dr. Jorge Eduardo da Silva Alvim • OAB/MG 222.943 • Juiz de Fora - MG • Padrão Enterprise (Prov. 205/2021 OAB & LGPD)

4. INTEGRAÇÕES CRÍTICAS: GATEWAYS DE COBRANÇA E TRIBUNAIS

RESILIÊNCIA

- Idempotência de Pagamentos (Evitar Duplicidade de Cobrança): Gateways (Asaas, Mercado Pago, etc.) reenviam Webhooks se houver atraso na resposta de 200 OK. O sistema deve registrar uma tabela processed_webhooks(event_id, processed_at) garantindo que nenhuma baixa contratual seja duplicada.
- Circuit Breaker em APIs Governamentais (DataJud/PJe): Websockets e APIs de Tribunais sofrem indisponibilidades e bloqueios por rate limit. O sistema deve implementar tentativas com backoff exponencial e Circuit Breaker, evitando travamento do event loop do Node.js.

5. SEGURANÇA, TRAVA ÉTICA OAB E CICLO DE VIDA DE DADOS

CONFORMIDADE LEGAL

- Harmonização Art. 18 vs Art. 16, I da LGPD: O direito de exclusão do titular cede perante a obrigação legal e regulatória do controlador (Art. 16, I). Advogados respondem pelos prazos prescricionais de 5 anos (CDC/Código Civil) e deveres éticos do Estatuto da OAB.
- Regra de Bloqueio no Portal: Se o cliente solicitar exclusão tendo processos ativos, o sistema rejeita automaticamente com aviso formal da LGPD e orienta a revogação formal de mandato junto ao patrono da causa.
- Expurgo Automatizado de Documentos: Criação de rotina diária no Node (cron job) para limpar da pasta /storage/temp/ fotos e arquivos descartados ou abandonados há mais de 7 dias.

6. MATRIZ DE RISCO & ESFORÇO TÉCNICO

PRIORIZAÇÃO

Componente	Vulnerabilidade Diagnosticada	Severidade	Esforço	Ação de Engenharia Recomendada
Exclusão de Conta	DELETE direto apaga processos e histórico judicial	ALTA	2 horas	Soft Delete + Trava OAB de processo
Rede VPS Contabo	Latência de 300ms perceptível em redes 4G brasileiras	ALTA	2 horas	Ativar Cloudflare CDN/Proxy gratuito
Backup Off-site	Snapshots ficam apenas no mesmo disco local	ALTA	3 horas	Upload automático p/ Google Drive ou S3
Webhooks Pagamento	Ausência de tabela de idempotência em retentativas	MÉDIA	4 horas	Filtro por transaction_id único
Storage Temporário	Acúmulo de fotos e rascunhos não finalizados	BAIXA	2 horas	Cron job diário de expurgo > 7 dias

7. ROADMAP EXECUTIVO DE IMPLEMENTAÇÃO EM 3 FASES

PLANO PRÁTICO

FASE 1: BLINDAGEM (48 HORAS)

- Soft Delete com trava Art. 16 LGPD.
- Ativação de Cloudflare Edge no Brasil.
- Backup externo automatizado (DRP).

FASE 2: CONFIABILIDADE (7 DIAS)

- Idempotência em webhooks PIX/cartão.
- Circuit breaker em APIs judiciais.
- Sanitização de segredos em .env.

FASE 3: GOVERNANÇA (15 DIAS)

- Cron diário de expurgo de arquivos.
- Rotina de anonimização periódica.
- Monitoramento de logs e alertas.

PARECER FINAL DO ARQUITETO:

A arquitetura Node.js + SQLite WAL na Contabo é altamente viável e de baixo custo. As 3 melhorias de Fase 1 garantem nível de segurança Enterprise e conformidade jurídica plena sem qualquer necessidade de contratação de nuvens caras.

